

INTERNAL MEMO

Risk Assessment Framework Recommendation

TO: CIO, CISO, Chief Risk Officer, Compliance Leadership
FROM: Risk & Compliance Advisory
DATE: 18th June 2026
RE: Risk Assessment Framework Adoption — Recommendation and 90-Day Implementation Plan

1. Executive Summary

Without a structured framework before adopting cloud infrastructure Northstar is exposed to much greater risks and threats as Northstar lacks the ability to identify, detect and prioritize risks. A gap which threatens to expose patient data is created because of inconsistent data, no auditable evidence of control effectiveness and no defined ownership. This inability to demonstrate compliance has led to increased scrutiny from HIPAA auditors and state regulators. This memo recommends a phased approach for adopting ISO 27001/27005/27799 family to establish data maturity required for FAIR based quantitative risk or NIST SP 800-66r2 modelling once the foundation is established. A 90-day implementation plan is outlined below.

2. Key Drivers Shaping Framework Selection

Northstar's regulatory, operational and cultural environment has played a major role in the selection and implementation of the recommended framework:

Regulatory

- HIPAA audit pressure requires defensible, structured repeatable risk assessments.
- Multi-state regulation introduces layered compliance obligations beyond federal minimums.
- Frameworks require documented evidence of control effectiveness.

Operational

- Cloud migration and telemedicine expansion increases threat surface.
- Legacy systems used increase attack surface.
- Inconsistent qualitative data means Northstar cannot support quantitative modeling.

Cultural

- Lack of clear ownership creates accountability gap.
- Line 2 is not effectively challenging Line 1 operations.
- No established security cadence to discuss the current posture and improvement required.

3. Framework Recommendation

Northstar's current risk program produces data that no framework can be used effectively. OCTAVE lacks the auditability which HIPAA demands. NIST RMF is designed for federal systems which will be operationally heavy to implement for private healthcare organizations. While NIST SP 800-66r2 maps directly with specific controls from HIPAA, it expects organizations to have a stable governance structure and defined asset inventory which Northstar does not have yet. FAIR requires data maturity Northstar has not established.

The phased hybrid path is therefore recommended where ISO 27001/27005/27799 will act as the immediate foundation, building the governance structure, documentation, and data quality those frameworks require. ISO family was chosen specifically because it is more adaptable to Northstar's active cloud migration and multi-state complexity than a specific control framework at this stage.

Framework	Role	Regulatory Fit	Operational Fit	Cultural Fit
ISO 27001	Governance structure	Establishes ISMS with documented policies and controls satisfying HIPAA audit requirements	Helps mitigate risks, lowers threat surface. Creates auditable data. Implementable without data maturity	Imposes governance discipline through restructuring.
ISO 27005	Risk methodology	Iterative risk assessments meet HIPAA and multi-state operation requirements.	Flexible enough for legacy systems and active cloud migration	Builds security risk culture with accountability.
ISO 27799	Healthcare extension	Maps controls directly to patient data obligations under HIPAA	Establishes overall ePHI, helps in telemedicine expansion	Familiar language for clinical and compliance teams
FAIR / NIST 800-66r2	Phase 2 destination	Supports auditable, quantifiable and financially defensible risk analysis	Fair for risk quantification or NIST 800-66r2 for HIPAA control mapping, direction chosen once ISO establishes data maturity.	Gives leadership quantifiable financial insight to align business goals

4. Practical Adaptation

ISO 27001

- Hurdle: No asset inventory, owner and budget to define ISMS scope, and baseline understanding of legal obligations.
- Adaptation: Start with limited scope gathering information regarding assets affected by cloud migration and telemedicine expansion.

ISO 27005

- Hurdle: Inconsistent risk assessment methodology, no threat/vulnerability library, no defined Risk appetite.
- Adaptation: Clearly define organizational risk appetite and separately for cloud migration, bring all three healthcare operations across states under one criterion before the implementation begins, start vulnerability identification scans.

ISO 27799

- Hurdle: No understanding of ePHI data flows mapped to HIPAA controls.
- Adaptation: Documenting data flows while cloud migration and establishing data flows for systems involved in telemedicine expansion.

FAIR / NIST SP 800-66r2

- Hurdle: No baseline established for governance, risk management, compliance and data.
- Adaptation: Implement ISO frameworks to establish baseline requirements for prioritization and quantification of risks.

5. 30-60-90 Day Implementation Plan

The following 90-day plan is structured around six focus areas deliberately selected for their cross-standard overlap. Each milestone simultaneously advances ISO 27001 governance requirements, ISO 27005 risk methodology inputs, and ISO 27799 healthcare-specific controls, maximizing implementation progress across all three frameworks within a single sequenced effort.

It is important to note that 90 days is not sufficient to fully implement any enterprise risk framework. The goal of this plan is to establish prerequisites to make full implementation possible, positioning Northstar to sustain and expand the program beyond this initial period.

Timeframe	Focus Area	Action to Take	Owner	Dependencies
Days 1–15	Governance Foundation	Establishment of RACI, Charters, risk committee.	CRO + CISO	Board-level approval to initiate framework adoption.
Days 16–30	Asset Management	Asset inventory completed for cloud migration, ePHI data flows and medical devices.	IT + Risk Committee	Documented risk accountability with governance structure in place before inventory begins.
Days 31–45	Risk Assessment	Standardized controls and scoring criteria, first risk assessments on telemedicine and cloud migration platform.	Risk Committee	Asset inventory and knowledge of risk assessment methods.
Days 46–60	Risk Treatment + Access Control	Controls selected from ISO 27001 Annex A; clinical access framework defined with least privilege and role-based access.	IT + CISO + Risk Committee	Complete risk structure with assessment method documented and understood.
Days 61–75	Cryptography + Incident Management	Same encryption policy established in all states, breach notification and auto escalation to incident response and management.	Security team + IT + Risk Committee	Complete knowledge of workflow, data flow and assets management in place.
Days 76–90	Monitoring + Compliance + Phase2 Readiness	First KRIs, KPIs, KCIs reported to CRO and CISO. Line 2 review cadence established, FAIR or NIST 800-66 readiness assessed, Phase 2 roadmap presented.	CISO + CRO + Internal Audit + IT + Risk Committee	Successful first implementation and documentation of Risks, threats, vulnerabilities.

6. Governance and Accountability Achievements

Successful completion of the above plan will correspond to the following immediate positive changes in the organization:

- Governance structure aligned with HIPAA and industry standards.
- Clearly defined processes and Executive accountability with RACI, charters bolstering documented evidence.
- Complete asset inventory and risk register established, full organizational risk scope documented and accessible.
- Reporting cadence to CRO with KRIs.
- Line 2 is formally able to challenge Line 1.
- Quarterly framework review.

7. Conclusion

With immediate implementation of ISO family, Northstar will be able to face the HIPAA scrutiny more confidently as ISO 27001/27005/27799 establishes the governance foundation the organization is currently missing. The ISO implementation allows Northstar to achieve FAIR based risk posture quantification in Phase-2 or NIST SP 800-66 control mapping for HIPAA regulation. Thus, transforming NorthStar's reactive compliance to proactive, documented, auditable and financially defensible risk management.